

VIETNAM NATIONAL UNIVERSITY, HO CHI MINH CITY
UNIVERSITY OF SCIENCE
FACULTY OF INFORMATION TECHNOLOGY



Báo cáo đồ án 2

**Topic: Xây dựng Ứng dụng Web Serverless với Kiến trúc
bảo mật & Tối ưu chi phí**

Course: Nhập môn điện toán đám mây

Prepared by

Nguyễn Minh Tú 23120101

Nguyễn Xuân Duy 23120121

Nguyễn Minh Hiếu 23120124

Ngày 7 tháng 6 năm 2026

Mục lục

I	Giới thiệu	3
1	Phạm vi ứng dụng	3
2	Tóm tắt triển khai	3
3	Thông tin endpoint	4
II	Kiến trúc hệ thống	5
1	Các thành phần chính	6
2	Resource chính	7
3	Luồng request	7
4	Tự mở rộng serverless	8
5	CDN và Origin Access Control	8
6	VPC Endpoint	9
III	Kết quả và bằng chứng	10
1	Bằng chứng bảo mật frontend	10
2	Bằng chứng Cognito và API security	11
3	Bằng chứng networking	13
4	Bằng chứng IAM	15
5	Giám sát	16
6	Chi phí	18
IV	Chi tiết triển khai	21
1	Source code	21
2	Các triển khai	21
V	Evaluation	22
1	Bảng đánh giá theo rubric	22
2	Phân chia công việc	24
A	Phụ lục	25

1	Checklist bằng chứng bắt buộc	25
2	Prompt GenAI	25
3	Ghi chú source code	25

I Giới thiệu

1 Phạm vi ứng dụng

Ứng dụng Task Manager hỗ trợ các chức năng chính sau:

- Đăng ký và đăng nhập người dùng thông qua Amazon Cognito.
- Tạo, xem, cập nhật và xóa công việc.
- Lưu trữ dữ liệu công việc bền vững trong Amazon DynamoDB.
- Chỉ cho phép người dùng đã xác thực gọi các API `/tasks`.

2 Tóm tắt triển khai

Các điểm triển khai chính của hệ thống:

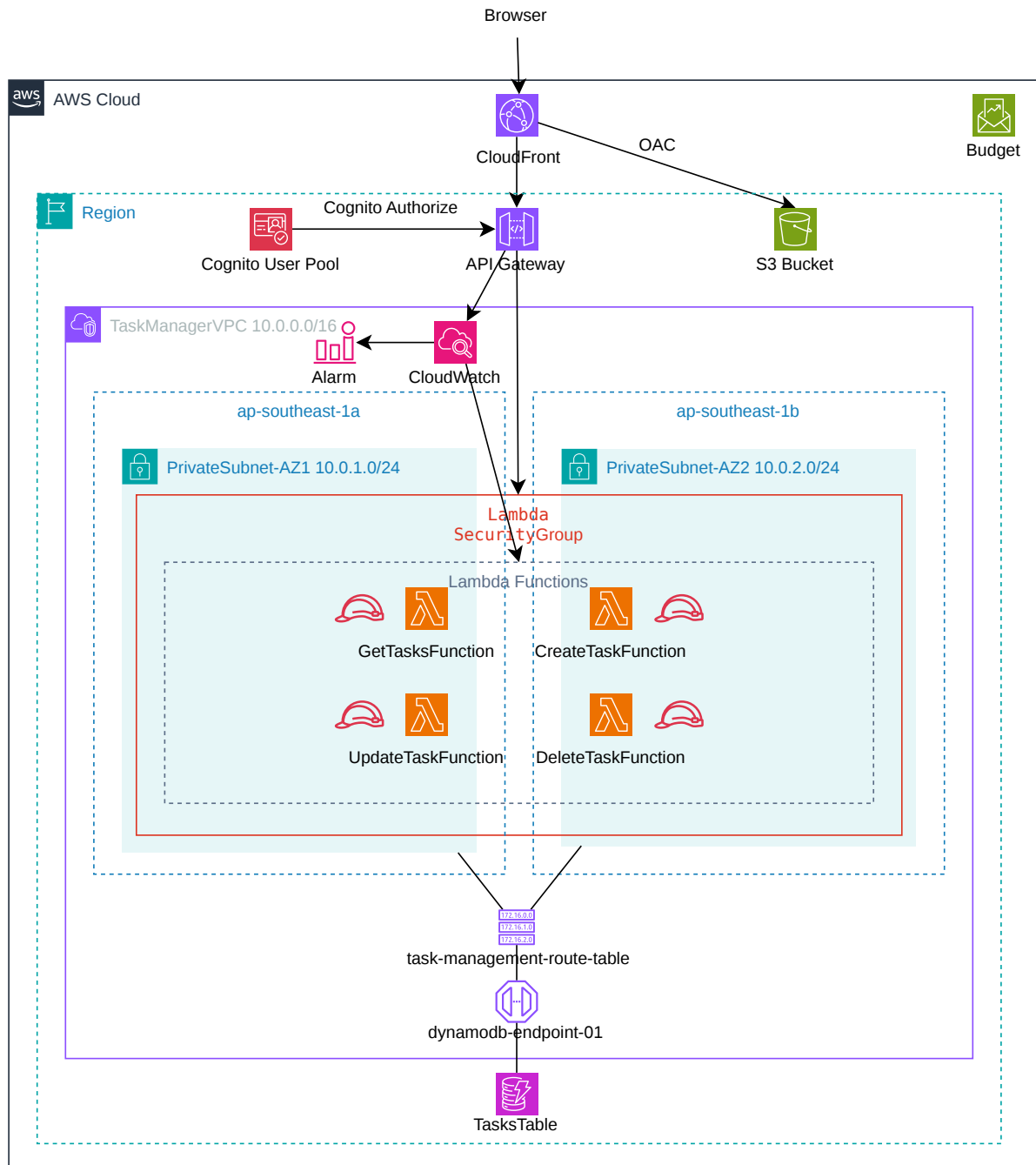
- Frontend được lưu trong S3 bucket riêng tư và chỉ được phục vụ qua CloudFront.
- CloudFront sử dụng Origin Access Control (OAC) để đọc object từ S3.
- Backend sử dụng API Gateway REST API stage `prod` và bốn Lambda function riêng biệt.
- Runtime của Lambda là Node.js 20.x.
- Lambda được đặt trong private subnet của custom VPC `TaskManagerVPC`.
- Lambda truy cập DynamoDB thông qua DynamoDB Gateway VPC Endpoint.
- API được bảo vệ bằng Cognito Authorizer.
- IAM được cấu hình theo nguyên tắc least privilege với bốn role riêng cho bốn Lambda function.
- CloudWatch Dashboard, CloudWatch Alarms, SNS và AWS Budget được cấu hình để giám sát và kiểm soát chi phí.

3 Thông tin endpoint

Thông tin	Giá trị
AWS Region	ap-southeast-1
CloudFront URL	https://d1ikfum6io2m2d.cloudfront.net/
API Gateway URL	https://x8hr2ow73f.execute-api.ap-southeast-1.amazonaws.com/prod/
S3 bucket frontend	https://taskmanager-ui-hieunguyen.s3.ap-southeast-1.amazonaws.com/index.html

Bảng 1: Thông tin triển khai thực tế của hệ thống

II Kiến trúc hệ thống



Hình 1: Sơ đồ kiến trúc serverless của ứng dụng Task Manager

1 Các thành phần chính

Thành phần	Vai trò
Amazon S3	Lưu trữ các file frontend. Bucket được đặt private, bật toàn bộ Block Public Access và không bật Static Website Hosting.
Amazon CloudFront	CDN duy nhất phục vụ frontend cho người dùng. CloudFront lấy file từ S3 thông qua OAC.
Origin Access Control	Cho phép CloudFront truy cập S3 private bucket một cách an toàn, không cần public bucket.
Amazon Cognito	Quản lý đăng ký, đăng nhập và phát hành JWT token cho frontend.
API Gateway REST API	Cung cấp HTTPS endpoint, định tuyến request đến Lambda, kiểm tra JWT bằng Cognito Authorizer và áp dụng throttling.
AWS Lambda	Chạy backend serverless bằng Node.js 20.x. Bốn Lambda function tách riêng tương ứng với bốn thao tác CRUD.
Amazon VPC	Cô lập tầng compute trong custom VPC TaskManagerVPC với hai private subnet.
DynamoDB Gateway Endpoint	Định tuyến traffic từ Lambda đến DynamoDB qua AWS private backbone, không cần NAT Gateway.
Amazon DynamoDB	Lưu trữ dữ liệu công việc trong bảng TasksTable , có GSI userId-index .
IAM	Cấp quyền least privilege bằng các role riêng cho từng Lambda function.
CloudWatch, SNS, AWS Budget	Giám sát metric, log, cảnh báo lỗi qua email và kiểm soát chi phí hàng tháng.

Bảng 2: Vai trò của các dịch vụ AWS trong hệ thống

2 Resource chính

Loại resource	Tên đã sử dụng
VPC	TaskManagerVPC
Private subnet AZ-1	PrivateSubnet-AZ1, CIDR 10.0.1.0/24, AZ ap-southeast-1a
Private subnet AZ-2	PrivateSubnet-AZ2, CIDR 10.0.2.0/24, AZ ap-southeast-1b
Security group	LambdaSecurityGroup
DynamoDB table	TasksTable
DynamoDB GSI	userId-index
Cognito User Pool	TaskManagerUserPool
Cognito App Client	WebAppClient
API Gateway REST API	TaskManagerAPI
CloudWatch Dashboard	TaskManager-Dashboard
AWS Budget	TaskManager-Budget-0.01

Bảng 3: Các resource chính của hệ thống

3 Luồng request

Khi người dùng mở ứng dụng, trình duyệt truy cập CloudFront domain. Nếu các file tĩnh như `index.html`, CSS và JavaScript đã có trong cache, CloudFront trả về trực tiếp từ edge location. Nếu cache miss, CloudFront lấy object từ S3 private bucket thông qua OAC. S3 bucket không public nên truy cập trực tiếp đến URL S3 sẽ bị từ chối.

Luồng tạo công việc sau khi người dùng đăng nhập:

1. Người dùng đăng nhập bằng Cognito và nhận JWT token.
2. Frontend gửi request HTTPS đến API Gateway endpoint `/tasks`, kèm header `Authorization`.
3. API Gateway dùng Cognito Authorizer để xác thực JWT token.
4. Nếu token hợp lệ, API Gateway gọi Lambda function tương ứng.
5. Lambda function chạy trong private subnet của `TaskManagerVPC`.
6. Lambda gửi request đến DynamoDB qua route table có destination là DynamoDB prefix list và target là VPC endpoint.

7. DynamoDB ghi hoặc đọc dữ liệu trong `TasksTable`.
8. Lambda trả JSON response về API Gateway, sau đó API Gateway trả kết quả về trình duyệt.

4 Tự mở rộng serverless

Hệ thống không cần Application Load Balancer vì API Gateway đã đóng vai trò entry point HTTPS và định tuyến request đến Lambda. Khi có nhiều request đồng thời, Lambda tự động tạo thêm execution environment để xử lý song song. Khi không có request, Lambda có thể giảm về không instance đang chạy, giúp giảm chi phí vận hành.

Để tránh runaway cost và bảo vệ giới hạn Free Tier, reserved concurrency được cấu hình như sau:

Lambda function	Reserved concurrency	Lý do
<code>GetTasksFunction</code>	5	Cho phép nhiều request đọc danh sách song song trong demo.
<code>CreateTaskFunction</code>	2	Giới hạn thao tác ghi mới để kiểm soát chi phí và lỗi lặp request.
<code>UpdateTaskFunction</code>	2	Đủ cho demo cập nhật đồng thời, vẫn giới hạn mức ghi.
<code>DeleteTaskFunction</code>	1	Xóa task là thao tác ít dùng hơn và nên được giới hạn chặt.

Bảng 4: Reserved concurrency của các Lambda function

Nếu reserved concurrency đặt quá thấp, người dùng có thể gặp throttling dù hệ thống vẫn còn khả năng xử lý. Nếu đặt quá cao, lỗi vòng lặp hoặc lượng request bất thường có thể tạo nhiều invocation và làm tăng chi phí.

5 CDN và Origin Access Control

CloudFront giúp giảm độ trễ bằng cách cache static assets tại edge location gần người dùng. Khi cache hit, CloudFront trả nội dung mà không cần truy cập lại S3. Khi cache miss, CloudFront lấy nội dung từ origin là S3 bucket.

S3 bucket bắt buộc private vì frontend không được truy cập qua URL S3 trực tiếp. Origin Access Control là cơ chế cho phép CloudFront ký request đến S3 và bucket policy chỉ cho phép CloudFront

service principal đọc object từ distribution hợp lệ. Nhờ đó, CloudFront là public entry point duy nhất của frontend.

6 VPC Endpoint

Lambda được gắn VpcConfig vào hai private subnet để backend chạy trong mạng riêng. Vì private subnet không có NAT Gateway, Lambda không thể gọi DynamoDB qua internet công cộng. DynamoDB Gateway Endpoint giải quyết vấn đề này bằng cách thêm route đến DynamoDB prefix list trong route table của private subnet.

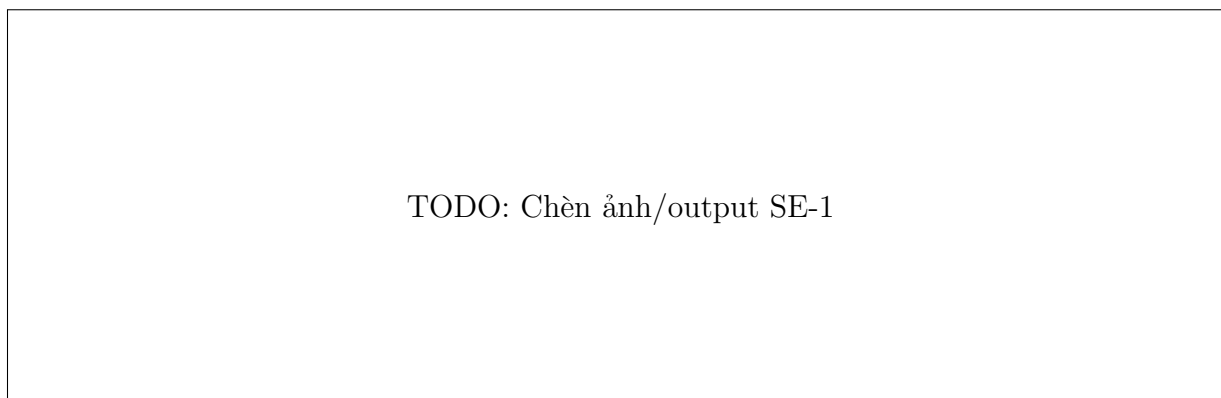
Traffic từ Lambda đến DynamoDB đi qua AWS private backbone theo đường: Lambda trong private subnet → route table → DynamoDB Gateway Endpoint → DynamoDB. Cách này an toàn hơn và không phát sinh chi phí cố định như NAT Gateway.

III Kết quả và bằng chứng

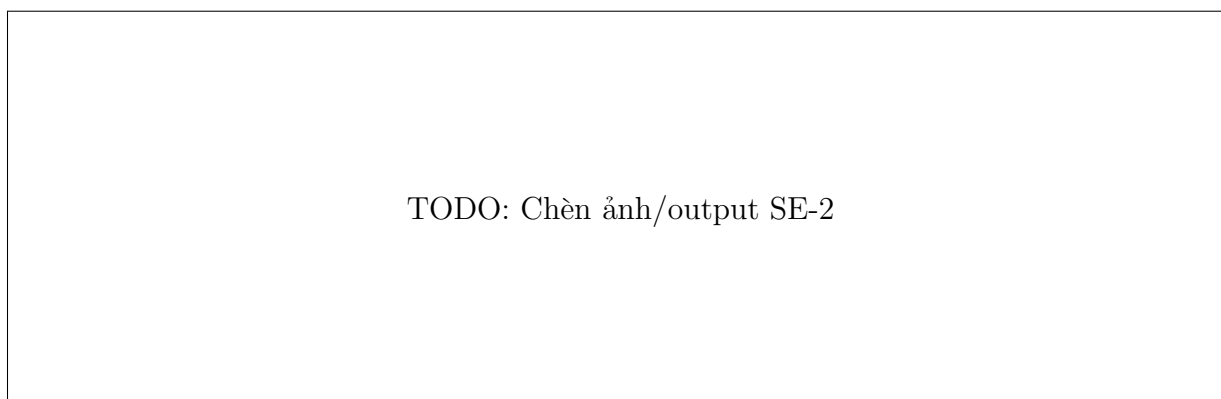
1 Bằng chứng bảo mật frontend

ID	Bằng chứng
SE-1	S3 Block Public Access bật cả bốn tùy chọn.
SE-2	Truy cập trực tiếp S3 URL trả về 403 Forbidden hoặc AccessDenied.
SE-3	Truy cập CloudFront URL thành công với 200 OK.
SE-4	CloudFront distribution có Origin Access Control.

Bảng 5: Bằng chứng bảo mật frontend



Hình 2: Ảnh/output bằng chứng SE-1



Hình 3: Ảnh/output bằng chứng SE-2

TODO: Chèn ảnh/output SE-3

Hình 4: Ảnh/output bằng chứng SE-3

TODO: Chèn ảnh/output SE-4

Hình 5: Ảnh/output bằng chứng SE-4

2 Bằng chứng Cognito và API security

ID	Bằng chứng
CO-1	Cognito User Pool <code>TaskManagerUserPool</code> đã tạo.
CO-2	API Gateway Cognito Authorizer đã cấu hình.
CO-3	Gọi API không có token trả về <code>401 Unauthorized</code> .
CO-4	Gọi API với token hợp lệ trả về <code>200 OK</code> .

Bảng 6: Bằng chứng Cognito và API security

TODO: Chèn ảnh/output CO-1

Hình 6: Ảnh/output bằng chứng CO-1

TODO: Chèn ảnh/output CO-2

Hình 7: Ảnh/output bằng chứng CO-2

TODO: Chèn ảnh/output CO-3

Hình 8: Ảnh/output bằng chứng CO-3

TODO: Chèn ảnh/output CO-4

Hình 9: Ảnh/output bằng chứng CO-4

3 Bằng chứng networking

ID	Bằng chứng
NE-1	DynamoDB Gateway Endpoint có status Available .
NE-2	Lambda có VpcConfig với private subnets và security group.
NE-3	Route table có dòng pl-xxxxxx -> vpce-xxxxxxxx .
NE-4	Không có NAT Gateway đang hoạt động.
NE-5	CloudWatch log cho thấy Lambda gọi DynamoDB thành công.

Bảng 7: Bằng chứng networking

TODO: Chèn ảnh/output NE-1

Hình 10: Ảnh/output bằng chứng NE-1

TODO: Chèn ảnh/output NE-2

Hình 11: Ảnh/output bằng chứng NE-2

TODO: Chèn ảnh/output NE-3

Hình 12: Ảnh/output bằng chứng NE-3

TODO: Chèn ảnh/output NE-4

Hình 13: Ảnh/output bằng chứng NE-4

TODO: Chèn ảnh/output NE-5

Hình 14: Ảnh/output bằng chứng NE-5

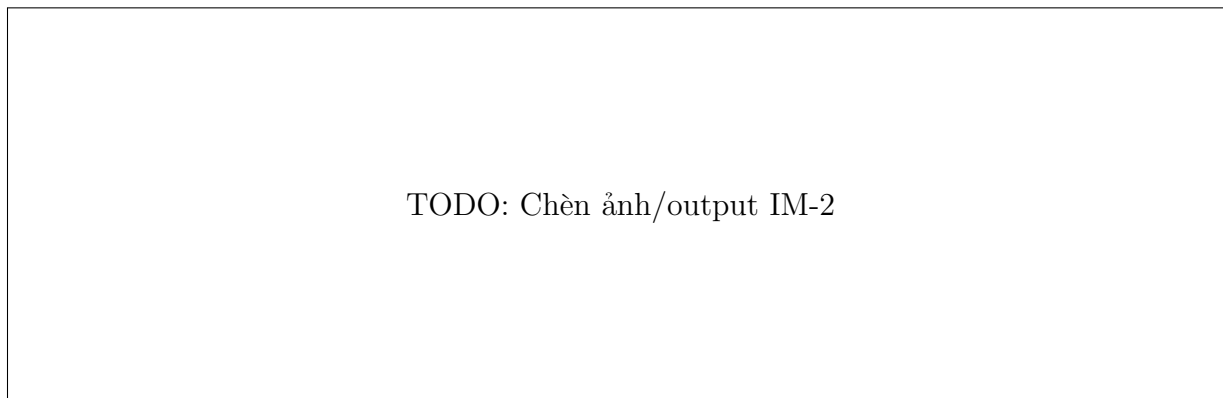
4 Bằng chứng IAM

ID	Bằng chứng
IM-1	Bốn IAM role riêng: <code>GetTasksLambdaRole</code> , <code>CreateTaskLambdaRole</code> , <code>UpdateTaskLambdaRole</code> , <code>DeleteTaskLambdaRole</code> .
IM-2	Policy JSON dùng ARN cụ thể của <code>TasksTable</code> và <code>userId-index</code> , không dùng resource <code>*</code> .
IM-3	Mỗi Lambda function gắn đúng IAM role tương ứng.

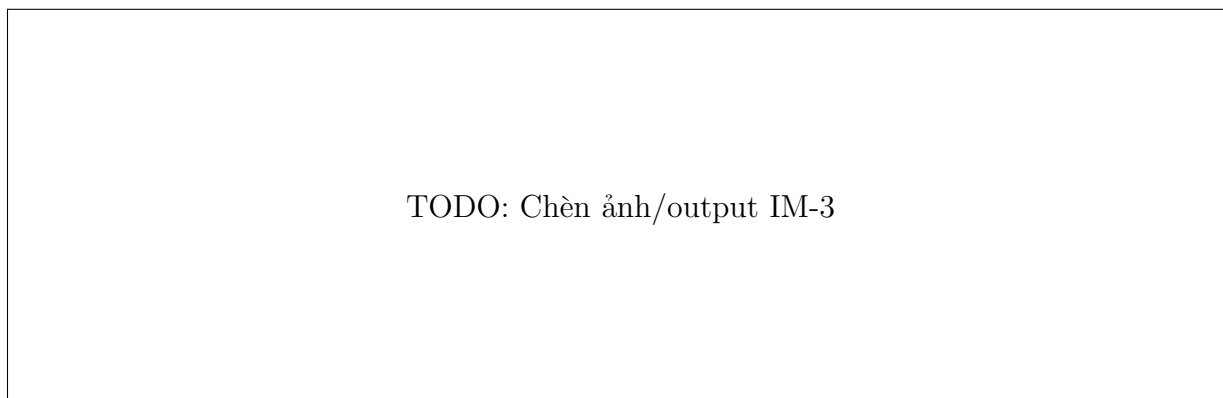
Bảng 8: Bằng chứng IAM

TODO: Chèn ảnh/output IM-1

Hình 15: Ảnh/output bằng chứng IM-1



Hình 16: Ảnh/output bằng chứng IM-2

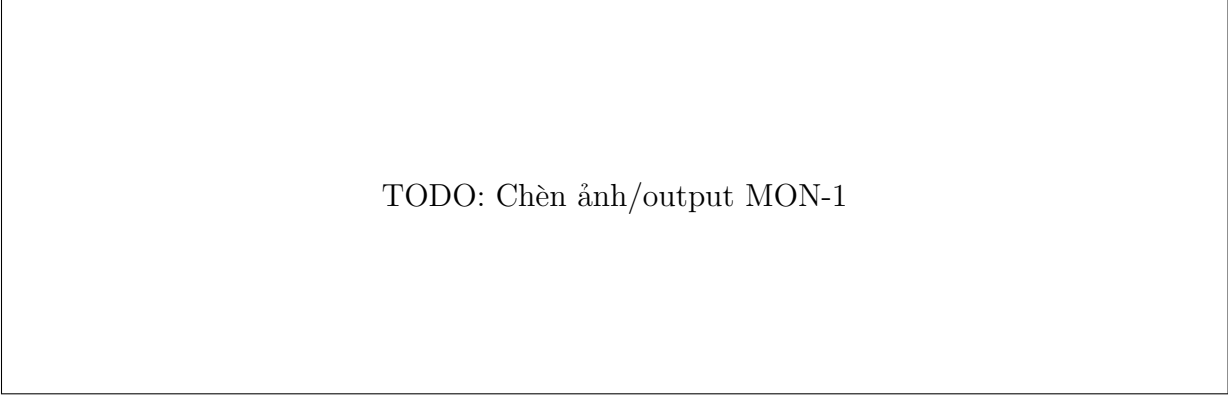


Hình 17: Ảnh/output bằng chứng IM-3

5 Giám sát

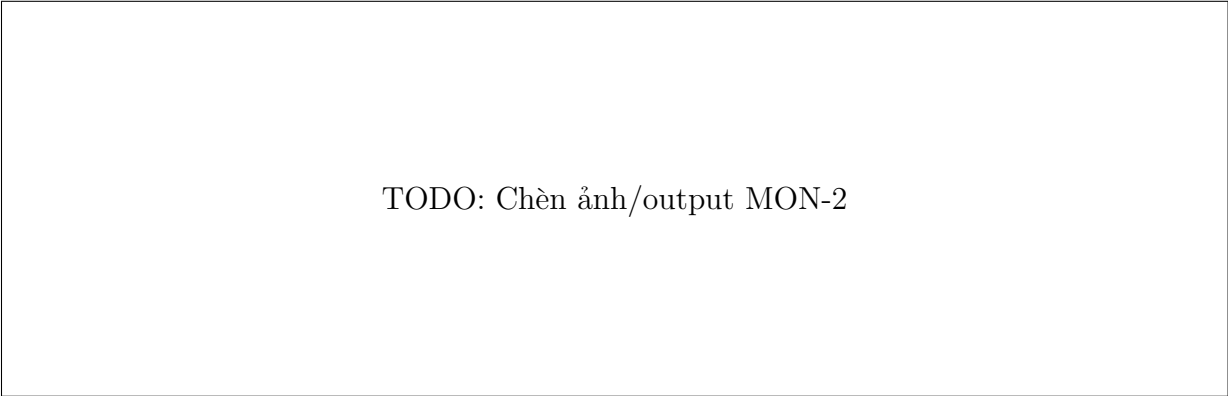
ID	Mục	Yêu cầu
MON-1	CloudWatch Dash-board	Tối thiểu 5 widget có dữ liệu thực.
MON-2	Lambda-Error-Alarm	Errors lớn hơn 10 trong 5 phút.
MON-3	API-5xx-Alarm	5XXError lớn hơn 5 trong 5 phút.
MON-4	Log request thành công	Có REPORT , status 200, duration, billed duration, memory used.
MON-5	Log request lỗi	Có lỗi validation hoặc stack trace khi input không hợp lệ.

Bảng 9: Bảng chứng monitoring và logging



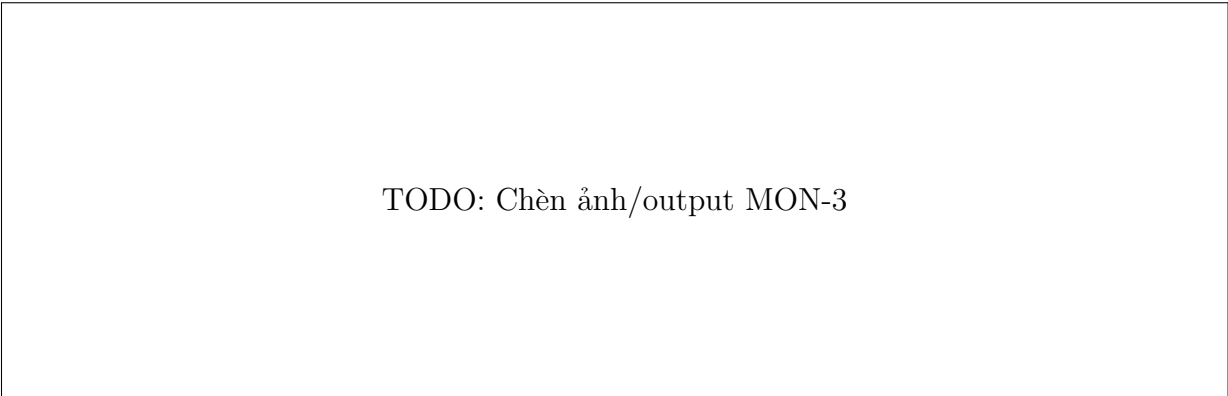
TODO: Chèn ảnh/output MON-1

Hình 18: Ảnh/output bằng chứng MON-1



TODO: Chèn ảnh/output MON-2

Hình 19: Ảnh/output bằng chứng MON-2



TODO: Chèn ảnh/output MON-3

Hình 20: Ảnh/output bằng chứng MON-3

TODO: Chèn ảnh/output MON-4

Hình 21: Ảnh/output bằng chứng MON-4

TODO: Chèn ảnh/output MON-5

Hình 22: Ảnh/output bằng chứng MON-5

6 Chi phí

ID	Mục	Giá trị
COST-1	Budget name	TaskManager-Budget-0.01
COST-2	Monthly budget	0.01 USD
COST-3	Alert 80%	0.008 USD
COST-4	Alert 100%	0.01 USD
COST-5	Actual cost	TODO: điền chi phí thực tế từ Billing Dashboard hoặc Cost Explorer

Bảng 10: Bảng chứng kiểm soát chi phí

TODO: Chèn ảnh/output COST-1

Hình 23: Ảnh/output bằng chứng COST-1

TODO: Chèn ảnh/output COST-2

Hình 24: Ảnh/output bằng chứng COST-2

TODO: Chèn ảnh/output COST-3

Hình 25: Ảnh/output bằng chứng COST-3

TODO: Chèn ảnh/output COST-4

Hình 26: Ảnh/output bằng chứng COST-4

TODO: Chèn ảnh/output COST-5

Hình 27: Ảnh/output bằng chứng COST-5

IV Chi tiết triển khai

- 1 Source code**
- 2 Các triển khai**

V Evaluation

1 Bảng đánh giá theo rubric

Bảng sau tổng hợp tiêu chí đánh giá theo rubric trong file yêu cầu đồ án `PROJECT2_VI.pdf` và cách hệ thống đã đáp ứng từng tiêu chí.

Hạng mục	Tỷ trọng	Yêu cầu điểm tối đa	Minh chứng trong báo cáo
Chức năng	20%	Bốn thao tác CRUD hoạt động đúng. Frontend, backend và DynamoDB tích hợp chính xác. Bộ lọc theo độ ưu tiên và ngày hết hạn hoạt động.	Bảng kiểm thử chức năng, demo frontend, dữ liệu trong DynamoDB.
Triển khai Đám mây	25%	S3 private và CloudFront OAC được xác minh. Lambda trong VPC có DynamoDB Endpoint. IAM least privilege với role riêng. Cognito xác thực đúng. CORS chỉ cho phép CloudFront domain.	SE-1 đến SE-4, NE-1 đến NE-3, IM-1 đến IM-3, CO-1 đến CO-4.
Hiểu biết Kiến trúc	20%	Giải thích được luồng request, VPC Endpoint, lý do thay thế NAT Gateway, Lambda auto-scaling, API Gateway load balancing, CloudFront caching và OAC.	Phần kiến trúc hệ thống, luồng request, serverless auto scaling, CDN/OAC và VPC Endpoint.
Giám sát	10%	CloudWatch Dashboard có ít nhất 5 widget với dữ liệu thực. Hai alarm được tạo. Có log request thành công, log request lỗi và SNS email notification.	Dashboard, alarms, log CloudWatch và SNS.
Hiệu quả Chi phí	15%	Không có NAT Gateway. Lambda reserved concurrency được giới hạn phù hợp. AWS Budget 0.01 USD được cấu hình. Tổng chi phí bằng 0 hoặc gần 0.	NE-4, reserved concurrency, bảng chi phí và AWS Budget.
Tài liệu	10%	Báo cáo giải thích đủ bốn khái niệm chính, sơ đồ kiến trúc đủ thành phần, đủ 16 mục bằng chứng SE/NE/IM/CO, có prompt GenAI nếu sử dụng, và nộp source code.	Báo cáo kỹ thuật, sơ đồ kiến trúc, phụ lục checklist, prompt GenAI và source code.
Tổng cộng	100%	Hệ thống được đánh giá dựa trên chức năng, bảo mật triển khai, hiểu biết kiến trúc, giám sát, chi phí và tài liệu nộp kèm.	

Bảng 11: Bảng đánh giá theo rubric của đồ án

2 Phân chia công việc

Bảng sau mô tả phân chia công việc trong nhóm. Tỷ lệ đóng góp được chia đều do các thành viên cùng tham gia triển khai, kiểm thử và hoàn thiện báo cáo.

Thành viên	MSSV	Công việc chính	Đóng góp
Nguyễn Minh Tú	23120101	Thiết kế frontend, cấu hình Cloud-Front/S3 private, kiểm thử truy cập frontend, hỗ trợ thu thập bằng chứng SE.	33.3%
Nguyễn Xuân Duy	23120121	Triển khai API Gateway, Cognito Authorizer, các Lambda function CRUD, kiểm thử xác thực JWT và endpoint API.	33.3%
Nguyễn Minh Hiếu	23120124	Thiết lập VPC, private subnets, DynamoDB Gateway Endpoint, DynamoDB table/GSI, IAM roles, CloudWatch, AWS Budget và tổng hợp báo cáo.	33.3%

Bảng 12: Bảng phân chia công việc nhóm

A Phụ lục

1 Checklist bằng chứng bắt buộc

ID	Bằng chứng	Đã có
SE-1	S3 Block Public Access bật cả bốn tùy chọn.	TODO
SE-2	Direct S3 access trả về 403 Forbidden.	TODO
SE-3	CloudFront access trả về 200 OK.	TODO
SE-4	OAC gắn vào CloudFront distribution.	TODO
CO-1	Cognito User Pool đã tạo.	TODO
CO-2	API Gateway Cognito Authorizer được cấu hình.	TODO
CO-3	API không có token trả về 401 Unauthorized.	TODO
CO-4	API có token hợp lệ trả về 200 OK.	TODO
NE-1	DynamoDB VPC Endpoint status Available.	TODO
NE-2	Lambda VpcConfig có private subnets và security group.	TODO
NE-3	Route table có route pl-xxxxxx -> vpce-xxxxxxx.	TODO
NE-4	Không có NAT Gateway đang hoạt động.	TODO
NE-5	CloudWatch log cho thấy Lambda gọi DynamoDB thành công.	TODO
IM-1	Bốn IAM role riêng cho bốn Lambda function.	TODO
IM-2	IAM policy dùng ARN cụ thể của DynamoDB table/index, không dùng resource *.	TODO
IM-3	Mỗi Lambda function gắn đúng role tương ứng.	TODO

Bảng 13: Checklist bằng chứng SE/CO/NE/IM

2 Prompt GenAI

Vì nhóm có sử dụng GenAI để hỗ trợ lập dàn ý và viết báo cáo, cần nộp kèm lịch sử prompt hoặc screenshot đoạn hội thoại theo yêu cầu đồ án.

- TODO: Chèn hoặc đính kèm lịch sử prompt đã sử dụng.
- TODO: Chèn screenshot hội thoại nếu nộp dưới dạng hình ảnh.

3 Ghi chú source code

Source code cần nộp kèm gồm:

- Frontend: HTML, CSS, JavaScript.
- Backend: mã Node.js 20.x cho bốn Lambda handler.
- README mô tả cách chạy local và cách deploy lên AWS.

Không có source code IaC vì hạ tầng được triển khai thủ công bằng AWS Console.